



Orviohub Phone Verification Plan

The recommended policy is:

Personal phone: optional by default, verified when used for security.
Organization phone: optional business contact, verified only when needed.
Branch phone: optional operational contact, normally not verified.

Email verification should remain the default account-verification method. The onboarding documents already recommend collecting the personal phone optionally and allowing users to skip optional profile fields.^[1]

1. Phone Number Types

Orviohub must treat these as three different data types.

Personal user phone

Belongs to the individual Orviohub account.

Used for:

- Account recovery.
- SMS notifications.
- SMS-based MFA.
- Security alerts.
- Support contact.
- Future phone login.

Organization phone

Belongs to the business or workspace.

Used for:

- Customer-facing business contact.
- Receipts.
- Invoices.
- Business profile.

- Billing or support communication.
- Organization contact information.

It should not automatically become the owner’s login or recovery number.

Branch phone

Belongs to one business location.

Used for:

- Branch contact information.
- Receipts.
- Customer support.
- Branch staff communication.
- Opening and closing operations.

It should not be treated as a security credential unless a future feature specifically requires that.

2. Verification Policy

Number	Required at creation?	Verification default	Verify when
Personal phone	No	Unverified	Recovery, MFA, SMS, phone login
Organization phone	No	Unverified	Billing, official business verification, sensitive support
Branch phone	No	Unverified	Branch alerts, OTP, automated calls
Personal email	Yes	Required	Account activation and recovery
Organization email	No	Optional	Customer contact, billing, official communication
Branch email	No	Optional	Branch communication or notifications

Do not force all users to verify a phone during signup. It adds onboarding friction and creates recurring SMS costs. The account should be usable with email verification alone.

3. Primary User Journey

A. Account signup

Screen

Create your Orviohub account

Required:

- First name.
- Last name.
- Email.
- Password.
- Terms acceptance.
- Privacy acknowledgement.

Optional:

- Phone number.
- Profile photo.
- Country.
- State.
- City.
- Preferred language.

If the user enters a phone number, show:

Phone verification is optional. You can verify it later if you want to use phone recovery or SMS security features.

Do not automatically send an SMS merely because the user entered a number.

Backend flow

1. Validate the email.
2. Normalize the email.
3. Validate the optional phone format.
4. Normalize the phone into international format.
5. Create the user.
6. Store the phone as unverified if provided.
7. Send the email-verification link.
8. Create a limited or pending session.
9. Continue to email verification.

The account should not be blocked simply because `phoneVerifiedAt` is empty.

B. Email verification

1. User opens the email link.
2. Backend verifies the one-time token.
3. `emailVerifiedAt` is set.
4. An audit event is created.
5. User continues to welcome or onboarding.

Email verification is required before:

- Creating a workspace.
- Activating an application.
- Accepting certain invitations.
- Performing sensitive account actions.

The existing onboarding plan already establishes email verification as the primary identity-verification step.^[2]

C. Optional phone verification

After email verification, show a non-blocking prompt:

```
Add a phone number for account recovery and security alerts.  
[Add phone] [Skip for now]
```

If the user skips:

- Continue onboarding.
- Do not repeatedly interrupt the user.
- Show a small reminder in account security settings.
- Ask again only when the user activates a phone-dependent feature.

If the user chooses to verify:

1. Enter phone number.
2. Normalize the number.
3. Send OTP.
4. User enters OTP.
5. Backend validates OTP.
6. Set `phoneVerifiedAt`.
7. Send confirmation notification.
8. Create audit event.

4. Backup User Journey

The backup journey handles users who cannot or do not want to use phone verification.

Scenario: User skips phone verification

```
Create account
→ Verify email
→ Skip phone verification
→ Create or join organization
→ Activate application
→ Use Orviohub normally
```

The user can still:

- Log in with email and password.
- Reset the password through verified email.
- Create or join organizations.
- Use Inventory.
- Receive email notifications.
- Manage products, branches, and team members according to permissions.

The user cannot use:

- Phone-based recovery.
- SMS MFA.
- Phone login.
- SMS-only operational alerts.

The UI should explain:

```
Your account is secure with email verification. Add and verify a phone later
if you want phone recovery or SMS security features.
```

Scenario: User enters the wrong phone number

1. User selects **Change phone number**.
2. Existing unverified number is marked replaced or expired.
3. New number is normalized.
4. New OTP is sent.
5. Previous OTP becomes invalid.
6. Audit event records the change.
7. Security notification is sent by email.

Scenario: User loses access to the phone

Use email-based recovery:

1. User signs in with email and password.
2. User opens account security.
3. User selects **Replace phone number**.
4. Require current password or recent authentication.
5. Verify the new phone if they want to use it.
6. Send a notification to the verified email.
7. Revoke pending phone OTP challenges.

Do not make the old phone the only recovery method.

Scenario: SMS provider failure

The user should see:

We could not send the verification code. You can try again later or continue using email verification.

Provide:

- Retry with rate limits.
- Change number.
- Continue without phone verification.
- Support reference ID.

Do not block account access because the SMS provider is temporarily unavailable.

5. Organization Phone Journey

Organization phone is collected during organization setup, not account signup.

Creation form

Business phone number (optional)
Used on receipts and business communications.

The owner may:

- Skip it.
- Enter it.
- Edit it later.
- Remove it later.

- Mark it as the preferred business contact.

Default behavior

When entered:

```
businessPhone
businessPhoneVerifiedAt: null
businessPhoneStatus: unverified
```

The organization can still be created.

Optional verification trigger

Request verification only when the organization wants to:

- Use the phone for billing contact.
- Receive payment or subscription alerts by phone.
- Use it as an official support number.
- Use it for WhatsApp integration.
- Display a “verified business contact” label.
- Complete a higher-trust business verification process later.

Organization phone verification should be controlled by a user with:

```
workspace.manage_contact
```

Do not let ordinary staff change it.

Organization phone replacement

1. Admin edits the number.
2. New number becomes pending.
3. Old verified number remains active until the new one is verified, if required.
4. Send OTP to the new number.
5. Verify the new number.
6. Send email notification to organization owner.
7. Write an audit event.

6. Branch Phone Journey

Branch phone should be collected in branch settings.

Creation form

Branch phone number (optional)
Used for branch contact details and receipts.

Default behavior:

```
branchPhone  
branchPhoneVerifiedAt: null  
branchPhoneStatus: unverified
```

No OTP should be sent by default.

Verify only when needed

Branch phone verification becomes required only if the branch uses the number for:

- SMS alerts.
- OTP approval.
- Automated phone calls.
- WhatsApp notifications.
- Sensitive operational workflows.
- Verified customer-facing contact.

Otherwise, format validation is enough.

Branch phone editing

Any user with:

```
branch.manage_contact
```

may edit the branch number.

If the number is not used for security:

- Save immediately.
- Audit the change.
- No OTP required.

If the number is used for security:

- Require re-authentication.

- Send OTP.
- Keep the old number active until replacement succeeds.
- Notify the branch manager and organization owner.

7. Data Model

User phone fields

```
users: {  
  phone?: string,  
  phoneNormalized?: string,  
  phoneVerifiedAt?: number,  
  phoneStatus?: "unverified" | "pending" | "verified" | "disabled",  
  phoneUsedForRecovery?: boolean,  
  phoneUsedForMfa?: boolean,  
}
```

Use a unique index on `phoneNormalized` only if one verified phone may belong to one account. If shared business numbers are allowed, do not enforce global uniqueness.

Phone verification challenges

```
phoneVerificationChallenges: {  
  userId?: Id<"users">,  
  workspaceId?: Id<"workspaces">,  
  branchId?: Id<"branches">,  
  
  phoneNormalized: string,  
  purpose: string,  
  
  codeHash: string,  
  status: "pending" | "verified" | "expired" | "cancelled",  
  
  attempts: number,  
  maxAttempts: number,  
  
  expiresAt: number,  
  verifiedAt?: number,  
  createdAt: number,  
}
```

Possible purposes:

```
user_phone_verification  
user_phone_change  
phone_recovery_setup  
sms_mfa_setup
```

```
workspace_phone_verification  
branch_phone_verification
```

Never store the raw OTP.

Organization phone fields

```
workspaces: {  
  phone?: string,  
  phoneNormalized?: string,  
  phoneVerifiedAt?: number,  
  phoneStatus?: "unverified" | "pending" | "verified",  
  phoneVerificationPurpose?: string,  
}
```

Branch phone fields

```
branches: {  
  phone?: string,  
  phoneNormalized?: string,  
  phoneVerifiedAt?: number,  
  phoneStatus?: "unverified" | "pending" | "verified",  
}
```

Keep user, organization, and branch phone fields separate. Never reuse a user's phone automatically as the organization phone.

8. API Plan

User phone APIs

```
GET    /v1/users/me/contact  
PATCH /v1/users/me/contact  
  
POST   /v1/users/me/phone/verification/start  
POST   /v1/users/me/phone/verification/verify  
POST   /v1/users/me/phone/verification/resend  
DELETE /v1/users/me/phone
```

Organization phone APIs

```
GET    /v1/workspaces/:workspaceId/settings/contact  
PATCH /v1/workspaces/:workspaceId/settings/contact  
  
POST   /v1/workspaces/:workspaceId/settings/phone/verification/start  
POST   /v1/workspaces/:workspaceId/settings/phone/verification/verify
```

```
POST /v1/workspaces/:workspaceId/settings/phone/verification/resend
DELETE /v1/workspaces/:workspaceId/settings/phone
```

Branch phone APIs

```
GET /v1/workspaces/:workspaceId/branches/:branchId/settings
PATCH /v1/workspaces/:workspaceId/branches/:branchId/settings

POST /v1/workspaces/:workspaceId/branches/:branchId/phone/verification/start
POST /v1/workspaces/:workspaceId/branches/:branchId/phone/verification/verify
POST /v1/workspaces/:workspaceId/branches/:branchId/phone/verification/resend
DELETE /v1/workspaces/:workspaceId/branches/:branchId/phone
```

The API must verify:

```
authenticated user
+ workspace membership
+ required permission
+ valid application access
+ valid branch access
```

Never trust the client's submitted role, workspace ID, or branch ID.

9. User Stories

Personal account

Optional phone

As a user, I want to skip entering my phone number so that I can create my Orviohub account without unnecessary friction.

Add phone later

As a user, I want to add a phone number later from account settings so that I can use recovery or SMS features when I need them.

Verify phone

As a user, I want to verify my phone number so that Orviohub can use it for the security feature I selected.

Recovery without phone

As a user, I want to recover my account through my verified email when I lose access to my phone.

Change phone

As a user, I want to replace my phone number securely without losing access to my account.

Privacy

As a user, I want my personal phone number hidden from ordinary organization members unless I choose to share it.

Organization

Add business phone

As an organization owner, I want to add a business phone number so that customers can contact my business.

Use on receipts

As an organization administrator, I want the business phone to appear on receipts and business documents.

Verify business phone

As an organization owner, I want to verify the business phone when I use it for official billing or support communication.

Edit business phone

As an authorized administrator, I want to update the organization phone while preserving an audit history.

Separate identity

As an organization administrator, I must not be able to change another user's personal phone or account recovery settings.

Branch

Add branch phone

As a branch manager, I want to add the branch phone so customers can contact that location.

Optional branch contact

As a branch manager, I want to leave the branch phone unverified when it is only informational.

Branch alerts

As a branch manager, I want to verify the branch phone when I enable SMS alerts.

Branch access

As a workspace administrator, I want to control who can edit branch contact information.

Preserve history

As an organization administrator, I want branch phone changes recorded without modifying historical receipts.

10. Verification Triggers

Use progressive verification instead of forcing verification at signup.

Trigger matrix

Feature	Phone required?	Verification required?
Create account	No	No
Verify account	Email	Email required
Create organization	No	No
Create branch	No	No
Password reset	No	Email
Phone recovery	Yes	Yes
SMS MFA	Yes	Yes
Phone login	Yes	Yes
SMS security alert	Yes	Yes
Business receipt display	No	No
Branch receipt display	No	No
Billing phone	Optional	Recommended

Feature	Phone required?	Verification required?
WhatsApp integration	Yes	Yes
Official business verification	Yes	Yes
High-risk action fallback	Optional	If selected as factor

11. Security Rules

OTP rules

- Generate cryptographically secure codes.
- Store only a hash.
- Expire codes quickly.
- Allow only one active challenge per purpose.
- Limit verification attempts.
- Limit resend requests.
- Invalidate old codes after a new code is issued.
- Do not reveal whether a phone number belongs to another account.
- Do not include OTP values in logs.
- Do not place OTPs in URLs.
- Record success and failure events without the code.
- Notify the user after phone changes.

Rate limits

Example initial limits:

```
Start verification: 3 per hour per target
Resend OTP: 3 per 15 minutes
Verify OTP: 5 attempts per challenge
Phone changes: 3 per day per account
```

Tune these through real usage. Do not make the limits so strict that legitimate Nigerian users with delayed SMS delivery are locked out.

Phone normalization

Store:

```
Original display number
Normalized E.164 number
```

Country code
Verification status

For Nigerian numbers, convert local formats such as 080 . . . to the appropriate international representation before sending SMS or comparing numbers.

SIM-swap caution

Do not treat a verified phone as equal to a password, TOTP, or passkey. SMS is useful for recovery and low-risk verification, but it is vulnerable to SIM swapping and other telecom attacks. Use TOTP or passkeys for stronger MFA when implemented. ^[3] ^[4]

12. Notifications and Audit Events

User notifications

- Phone verification started.
- Phone verified.
- Phone changed.
- Phone removed.
- Phone recovery enabled.
- SMS MFA enabled.
- SMS MFA disabled.
- Verification attempts exceeded.

Send critical notifications to verified email or in-app notifications.

Organization notifications

- Business phone added.
- Business phone verified.
- Business phone changed.
- Business phone removed.
- Verification failed repeatedly.

Notify the organization owner and billing administrators when applicable.

Branch notifications

- Branch phone changed.
- Branch phone verified.
- Branch phone removed.
- Branch SMS alerts enabled.

- Branch verification failed.

Audit events

```
user.phone_added
user.phone_verification_started
user.phone_verified
user.phone_verification_failed
user.phone_changed
user.phone_removed

workspace.phone_added
workspace.phone_verification_started
workspace.phone_verified
workspace.phone_changed
workspace.phone_removed

branch.phone_added
branch.phone_verification_started
branch.phone_verified
branch.phone_changed
branch.phone_removed
```

Include:

```
actorId
targetType
targetId
workspaceId
branchId
purpose
maskedPhone
requestId
ipAddress
userAgent
createdAt
```

Never include:

```
raw phone OTP
password
session token
recovery token
provider secret
full sensitive security details
```

13. Do's

- Do make email verification the required account-verification method.
- Do make personal phone verification optional initially.
- Do verify a personal phone when it is used for recovery, MFA, or phone login.
- Do keep organization phone separate from personal phone.
- Do keep branch phone separate from organization phone.
- Do allow organization and branch phones to remain unverified when they are only contact details.
- Do show whether a number is verified.
- Do use E.164 normalization.
- Do hash OTP codes.
- Do expire OTP challenges.
- Do rate-limit sending and verification.
- Do notify users when security phone details change.
- Do preserve the old verified phone until the replacement process succeeds when appropriate.
- Do provide email-based recovery.
- Do audit phone changes.
- Do allow authorized admins to edit business and branch contact numbers.
- Do use TOTP or passkeys for stronger MFA later.
- Do collect phone numbers progressively when a real feature needs them.

14. Don'ts

- Do not force phone verification for every new user.
- Do not block organization creation because the owner has no phone.
- Do not block branch creation because the branch has no phone.
- Do not use an organization phone for personal account recovery.
- Do not use a branch phone for login by default.
- Do not automatically copy the user's phone into the organization phone field.
- Do not expose a user's personal phone to every organization member.
- Do not allow workspace admins to change a user's personal phone.
- Do not store raw OTP codes.
- Do not log OTP codes.
- Do not use SMS as the only strong authentication factor.

- Do not make phone verification the only recovery option.
- Do not reveal whether a phone number belongs to another Orviohub account.
- Do not allow unlimited OTP requests.
- Do not immediately replace a verified phone before the new number is confirmed.
- Do not delete historical receipts when a branch phone changes.
- Do not rewrite old organization or branch records after contact details change.
- Do not use phone number alone to merge accounts.
- Do not treat a verified phone number as proof of legal business ownership.

15. Phased Implementation

Phase 1: Optional phone storage

Implement:

- User phone field.
- Organization phone field.
- Branch phone field.
- E.164 normalization.
- Masked display.
- Permission checks.
- Audit events.
- No OTP yet.

This lets the current onboarding and demo dashboard collect and display phone information safely.

Phase 2: Personal phone verification

Implement:

- OTP challenge table.
- Start verification.
- Verify OTP.
- Resend OTP.
- Change phone.
- Remove phone.
- Rate limits.
- Email notifications.
- Account security UI.

Phase 3: Feature-based requirements

Add verification requirements for:

- Phone recovery.
- SMS notifications.
- SMS MFA.
- Phone login.
- WhatsApp integration.

The user should only see the verification prompt when selecting one of these features.

Phase 4: Organization verification

Implement only if required by:

- Billing.
- Official business verification.
- Support workflows.
- WhatsApp or SMS business communication.

Phase 5: Branch verification

Implement only when branch-level SMS, WhatsApp, phone calls, or sensitive operational approvals are introduced.

16. Final MVP Acceptance Criteria

The phone system is ready when:

- A user can create an account without a phone number.
- Email verification is required before sensitive onboarding actions.
- A user can add a phone later.
- A user can verify the phone through OTP.
- A user can skip verification and continue using email.
- A user can recover access through email.
- Organization phone is separate from user phone.
- Branch phone is separate from organization phone.
- Organization and branch phones can remain unverified.
- Phone-dependent features require verification.
- OTP values are never stored or logged in plaintext.
- OTP requests and attempts are rate-limited.

- Phone changes generate notifications and audit events.
- Organization admins cannot modify personal account phone security.
- Branch managers cannot modify phones outside their authorized branch.
- Historical business records remain unchanged when phone details are edited.
- SMS failure does not lock the user out of Orvionhub.
- The system does not create unnecessary SMS cost during normal signup.

The best first implementation for Orvionhub is therefore:

```
Email verification: required
Personal phone: optional
Organization phone: optional
Branch phone: optional
Phone verification: feature-triggered
SMS MFA: optional and secondary
TOTP/passkeys: stronger future security method
```



1. docs/Orvionhub Account Signup and Onboarding Journey.pdf
2. docs/authentication and onboarding plans.pdf
3. <https://pages.nist.gov/800-63-4/sp800-63b.html>
4. https://cheatsheetseries.owasp.org/cheatsheets/Multifactor_Authentication_Cheat_Sheet.html